

Cloud Accounts

- Cloud user accounts are created and managed using **IAM services** provided by cloud platforms.
- IAM controls **who can access** cloud resources and **what they can do**.
- After user accounts are created, the **root account should only be used when absolutely necessary !!!**.

Identity

- **Logical access control** manages digital and remote access, unlike physical access control (e.g., door locks).
- **Identity** is a digital entity for users or resources, and roles and permissions are attached to it.
- Accounts for resources are called **service accounts**, while humans use **user accounts**.
- Accounts are created and managed through the **IAM dashboard**.
- Identities and their credentials are stored in an **identity vault**.

Account Management

- Effective account management policies help ensure that the following tasks occur:
 - Accounts are set up (provisioned) in a true time for new users
 - Suspicious accounts are locked out for protection
 - Privilege creep (unmonitored privilege growth) is limited
 - Unused accounts are closed .
- Another consideration is **whether and when users should be given multiple accounts**

Privilege creep = too many permissions over time

Privileged Access Management (PAM)

- **PAM (Privileged Access Management)** is a subset of IAM that applies **stricter rules** to users with **upgraded permissions**.
- Security precautions for privileged accounts include:
 - **Limited use** – used only when necessary
 - **Limited location** – access allowed only from specific locations
 - **Limited time** – access granted for a short time
 - **Limited access** – only required permissions are given
 - **Limited privacy** – activities are monitored and logged

Privileged = ayrıcalıklı / özel yetkili

Authentication

- **Authentication** is part of the **AAA model** used in NAC (Network Access Control)
- **Authentication** – proves who you are and lets you enter the system
- **Authorization** – decides what you are allowed to do in the system
- **Accounting** – records what you do for logging and review

- Authentication = *Who are you?*
- Authorization = *What can you do?*

- Accounting = *What did you do?*

Authentication Processes

- **Authentication** is managed by a server that verifies a user's identity and decides if access is allowed
- User identity is stored in a **directory service** that keeps account information
 - Example: **Microsoft Active Directory (AD)**
- Cloud authentication often uses **REST APIs**
 - **REST (Representational State Transfer)** is an architecture for HTTP/HTTPS communication
 - Client and server work independently
 - The server does **not** store client session data

Password Policies

- **Complexity** – use different characters
- **Length** – minimum number of characters
- **Expiration** – password changes after time
- **Lockout** – account locks after failed attempts

Multifactor Authentication (MFA)

- **MFA** requires **two or more authentication factors** from different categories.
- Main MFA factor categories:
 - **Something you know** – password or PIN
 - **Something you have** – phone, card, or token
 - **Something you are** – fingerprint or face
 - **Somewhere you are** – your location
 - **Something you do** – how you type or speak

Certificate-Based Authentication

- A **digital certificate** is a small file that proves an identity and contains a **public key**
 - If the certificate works correctly, it proves the user owns **both public and private keys**.
- **PKI (Public Key Infrastructure)** connects a public key to a real user by using a trusted certificate authority.
- Digital certificates are mainly used to **secure websites** and protect sensitive data

Single Sign-On (SSO)

- **SSO** lets a user **log in once** and access **multiple systems**
- Users **do not need many passwords** or to log in again for each service
- SSO commonly uses standards like **SAML** or **OpenID Connect**
- SSO uses a **single source of truth**, so user data is not duplicated
- **Federation** means sharing user identities **between organizations** based on trust

Digital Signatures

- A **digital signature** uses **public key cryptography** to prove who signed a document
- It confirms **authenticity** and **integrity** of the document
- If the **private key is stolen**, the signature can be forged (sahtesi yapılabilir.)
- A **digital signature is different from a digital certificate**
 - Signature = proves a document
 - Certificate = proves an identity (PKI)

👉 **Easy memory:**

Signature = *signing data*

Certificate = *proving identity*

Securing Secrets

- **Secrets management systems** protect and manage passwords, keys, and tokens
- Cloud platforms provide **built-in tools** for secrets management
- Secrets are stored in **secure vaults, not hard-coded** in code or scripts
- Applications **request secrets only when needed**, and they are sent securely

👉 **Easy memory:**

Secrets = store safely, don't hard-code, access when needed.

Securing Secrets – Status of Certificates

- **Good** – certificate is valid and trusted
- **Retired** – certificate is expired and cannot be used
- **Revoked** – certificate is compromised and must be blocked
- To revoke a certificate, a **revocation request** is sent to the **CA (Certificate Authority)**

AWS Identity and Access Management (IAM)

IAM terms used in AWS Environment :

- **User**
An identity for a person or application that uses AWS resources.
- **Root user**
The first and main account created when you open an AWS account.
- **Group**
A collection of users managed together.
- **Permission**
Defines what action an identity can do.
- **Policy**
A set of permissions attached to a user, group, or role.
- **Role**
An identity used to give permissions to AWS resources or services.

Azure Identity and Access Management (IAM)

- Azure manages IAM using **Azure AD (Active Directory)**
- Azure AD has a **flat structure**
 - No container hierarchy like Ous OU (organizational unit)

Main terms in Azure AD:

- **User** – a person who uses Azure
- **Group** – a collection of users
- **Service principal** – an identity for an application
- **Permission** – what an identity can do
- **Role** – a set of permissions
- **Scope** – where the role applies
- **Role assignment** – giving a role to an identity

Azure Identity and Access Management (IAM) – RBAC

- Azure uses **RBAC (role-based access control)** to control access to resources
- With RBAC, access is given based on **user roles and job duties**
- A supervisor describes what the user does
- The **admin assigns the needed permissions** for that role

Other access control models:

- **DAC (discretionary access control)** – resource owner decides access
- **MAC (mandatory access control)** – system rules decide access

GCP Identity and Access Management (IAM)

- GCP uses **similar IAM terms to Azure**
- Main IAM terms in GCP:
 - **User**
 - **Service account**
 - **Group**
 - **Permission**
 - **Role**
 - **Policy**

AWS IAM in a Hybrid or Multi-Cloud

- **AWS offers AWS Managed Microsoft AD**
 - Also called **AWS Directory Service for Microsoft Active Directory**
- **Directory Service is a managed directory service in AWS**
 - It can apply **AD features** to other AWS services
 - Supports traditional AD applications:
 - Remote Desktop
 - SharePoint
 - SQL Server
- **An AD trust relationship can be established**
 - Between **AWS Directory Service** and **on-prem AD**

Azure IAM in a Hybrid Cloud

- Azure offers **three options** to integrate IAM services in the cloud with on-prem workloads:
- **Cloud identity**
 - All IAM services are in the cloud
 - Limited password or credential synchronization
 - On-prem users authenticate through the cloud
- **Synchronized identity**
 - Identities exist **both on-prem and in the cloud**
 - Password **hashes** are synchronized between both locations
- **Federated identity**
 - Most **complex and expensive option**
 - Provides full SSO functionality
 - **Real-time authentication** between on-prem and cloud

GCP IAM in a Hybrid Cloud

- Google suggests using **one of two approaches** to extend identity services across a hybrid cloud:
 - **Extend the existing IdP to GCP**
 - The current identity provider is extended to GCP
 - **Merge the existing IdP with GCP's Cloud Identity service**
 - The existing IdP is federated with GCP Cloud Identity

Azure supports **cloud, synchronized, and federated** identity models for hybrid environments. GCP recommends extending an existing identity provider or federating it with Cloud Identity to enable hybrid IAM.